MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Persistence

Unit 10 · Ethical Hacking (10-151-160)

MID-STATE TECHNICAL COLLEGE

Learning Outcomes

By the end of this unit, you will be able to:



Explain the need for persistence

Articulate why maintaining a foothold matters and where persistence falls in the attacker workflow.



Research persistence techniques

Investigate how persistence is accomplished using the MITRE ATT&CK persistence tactic (TA0003).



Describe how attackers avoid detection

Explain how a foothold is made to blend in — common service names, legitimate-looking tasks.



Detect persistence

Identify the anomalies that give persistence away — connection length, odd hours, stray autostart entries.

LESSON 1

Why Persistence?



What Is Persistence?

In MITRE ATT&CK terms, the adversary is trying to maintain their foothold.

- **Persistence** keeps access across reboots, credential changes, and other interruptions that would otherwise cut off entry.
- Attackers abuse **built-in OS features** — registry keys, scheduled tasks, services — so the foothold looks like normal activity.
- Think of it as a piece of **tape over a door latch** so the door never quite locks behind them.



Why not just re-hack?

Regaining initial access is expensive and noisy. Persistence is the attacker's **safety net** — easy re-entry and a measure of certainty in an otherwise uncertain process.

The Goal of Persistence

A good persistence mechanism buys an attacker three things:



Stealth

It looks like normal system activity, so it survives not just reboots but casual inspection.



Access

A guaranteed way back in — often a second, hidden backdoor if the primary is found and closed.

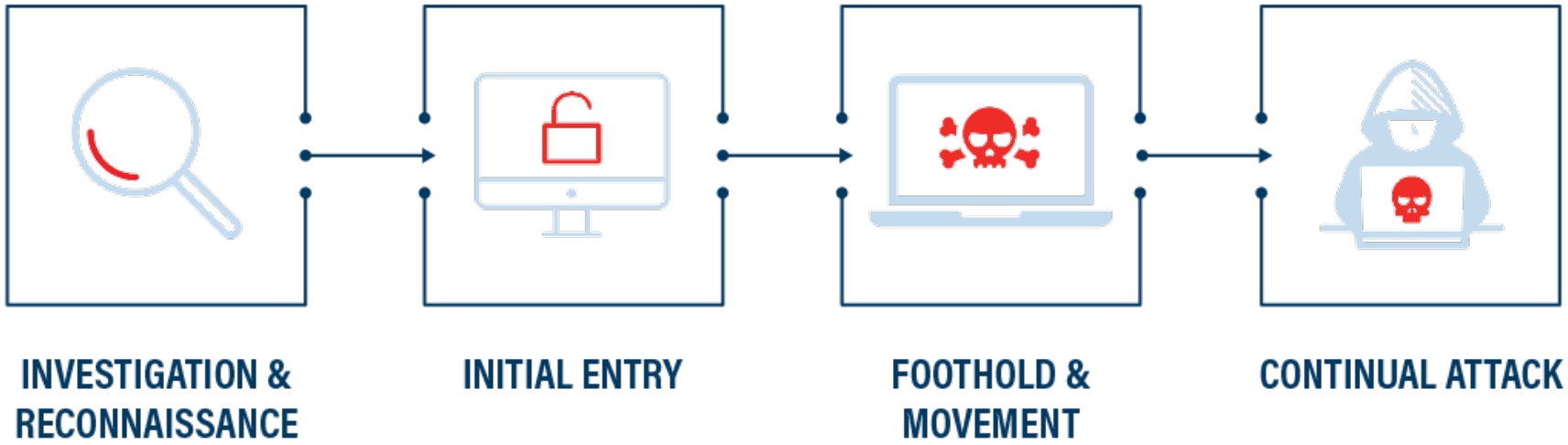


Dwell time

The longer undetected, the more an attacker accomplishes. Median dwell time has historically run to a few weeks.

Where Persistence Falls in the Workflow

Persistence is woven through the intrusion, not done once:



Established right after initial access to secure the foothold — then used to blend in, and to avoid getting caught while the attacker finishes the job.

LESSON 2

Achieving Persistence



MITRE ATT&CK: Persistence (TA0003)

ATT&CK catalogs persistence as tactic TA0003 — roughly 18–20 techniques, each with sub-techniques.

Technique	What the attacker abuses
Boot/Logon Autostart	Run keys and Startup folder — launch at logon
Scheduled Task / Job	Task Scheduler — run at startup or on a timer
Boot/Logon Init Scripts	Scripts auto-run at boot or logon
Event Triggered Execution	Fire on a system event (file creation, WMI)
Account Manipulation	Create or elevate a hidden backdoor account

Best practice for an attacker: use more than one technique at once, so losing one mechanism does not mean losing access.

Boot & Logon Autostart: Run Keys

The classic Windows foothold: an entry in a Run key launches a program every logon.

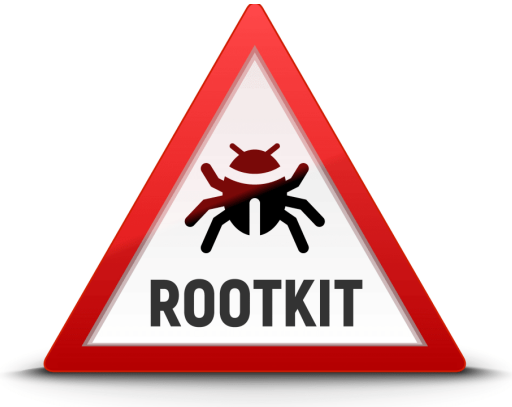


- `HKCU\...\Run` runs for the current user; `HKLM\...\Run` runs for every user on the machine.
- `RunOnce` keys execute a single time and then remove themselves.
- Because it abuses a **native OS feature**, it is hard to flag with prevention alone.

Rootkits & Firmware-Level Persistence

For persistence that is even harder to find, attackers go lower in the stack:

- **Rootkits** — subvert the OS's own view of files, processes, and connections to hide the intruder.
- **Bootkits** — persist in the boot process (MBR/UEFI), loading before the OS and any security tooling.
- **Firmware rootkits** — live in UEFI firmware, surviving OS reinstalls and even disk replacement.
- **Virtual rootkits** — run beneath the OS at the hypervisor layer, invisible to the guest.

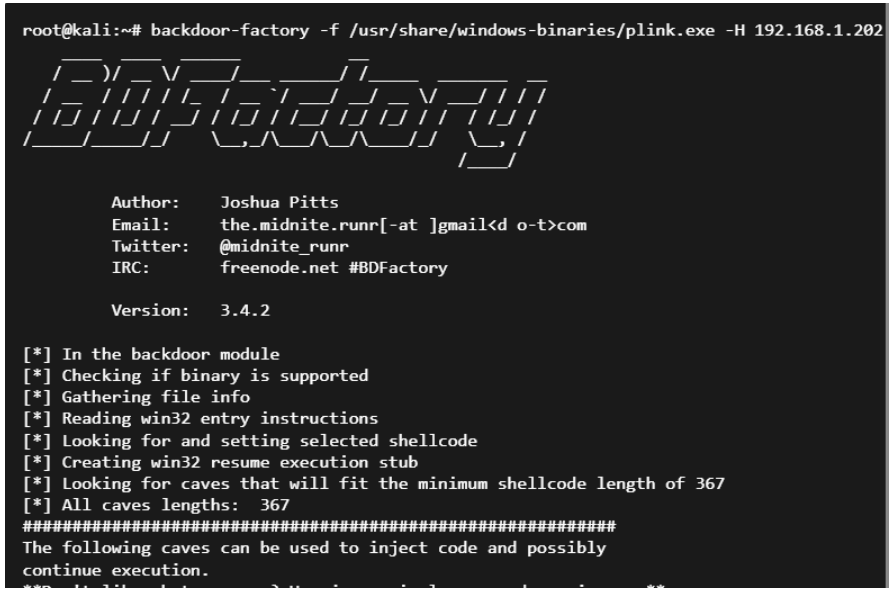


Lower in the stack = harder to remove.

Tools of the Trade

You do not need exotic tooling — most of it lives in frameworks you already know, or in the OS itself.

- **Metasploit / Meterpreter** — persistence modules and handlers that re-establish a session after reboot.
- **PowerShell** — a living-off-the-land favorite; plant Run keys, tasks, or WMI subscriptions with built-in tooling.
- **the-backdoor-factory** — patch a payload into a legitimate executable so it still runs normally.



LESSON 3

Avoiding Detection



What Persistence Looks Like

A scheduled task that fires every boot — read it the way a defender would:

```
cmd /c "start /b c:\ProgramData\48756e74.bat"
```

- The unusual file path in `C:\ProgramData` is the giveaway — open it and the intent is clear:

```
net user eviluser "SomeP@ssw0rd" /ADD
net localgroup administrators eviluser /ADD
```

Why tools miss it: creating a user from a prompt can be a legitimate admin task, so prevention often lets it run. Context — an odd task name and file path — is what catches it.

Blending In

A foothold is designed to look like something that belongs:

- **Common service names** — a malicious service named to resemble a real Windows service hides in a long list.
- **Legitimate-looking tasks** — scheduled tasks that mimic patch or update jobs so they read as routine.
- **Living off the land** — using built-in tools (PowerShell, WMI, schtasks) instead of dropping new binaries.
- **Normal file locations** — staging in paths admins expect to see written to, like `C:\ProgramData`.



The defender's inversion

Every blending tactic is also a **hunting lead**: a service whose name is almost right, a task that matches no patch cycle, a script run from an odd path.

LESSON 4

Detecting & Defending



Detecting Persistence

Persistence hides in plain sight — you find it by looking for what does not fit.

- **Endpoint monitoring (EDR)** — flags suspicious launches, new autostart entries, task and service tampering.
- **Antivirus** — catches the known-bad as one layer, but misses footholds built from legitimate features.
- **Network logs** — reveal beaconing and **unusually long-lived connections**, a classic tell.
- **Threat hunting** — a human looks for the anomalies tools pass: odd service name, odd-hour logon, stray task.

Prevention Alone Is Not Enough

In one vendor's incident data, persistent threats were found on endpoints that already ran security software:

Found on endpoints with	Share of persistent threats
One preventive product	73% — still got through
Two preventive products	19% — still got through

Takeaway: prevention is a layer, not the answer. Detection and human hunting are what actually close the gap.

Source: Huntress Security Platform incident data, Jan–May 2021 (base = 2,566).

Signs of an APT

When persistence is part of a patient, low-and-slow campaign, watch for these together:

- An increase in elevated logons late at night.
- Widespread backdoor trojans across multiple hosts.
- Unexpected information flows and outbound data bundles.
- Focused spear-phishing campaigns against specific staff.



Hardening Against Persistence

Hardening makes a foothold harder to establish and shrinks the attacker's options.

- **Reduce privileges** — many advanced techniques need elevation; least privilege makes them fail outright.
- **Restrict write locations** — block writes to staging spots like the public profile or `C:\ProgramData`.
- **Lock down config & registry** — make config read-only; apply ACLs to the Run keys so they can't be silently changed.
- **Review permissions regularly** — keep file-system rights as restrictive as possible.



SECURITY FOCUS

If you delete malware but miss the persistence behind it, it comes right back. Treat the foothold as the root cause, not the symptom.

Why it matters: Removing the payload without the persistence just resets the attacker's timer.

The Human in the Hunt

Persistence is not a problem you can fully automate away.



SECURITY FOCUS

Some evasion slips straight past automated solutions. A real person doing the detective work is often what roots out a foothold before it does major damage — and when a foothold relies on something the business genuinely needs, you convert it into a **documented control requirement** (residual risk, compensating monitoring, an owner) rather than closing the ticket.

Why it matters: The foothold you cannot remove is a tracked, monitored exposure — never a forgotten one.

Hands-On Lab: Make Your Malware Persist

Your Kali VM → your paired Windows target · then TryHackMe: Registry Persistence Detection · lab-only, authorized target only.



- Obtain an initial session and apply at least one persistence technique.
- Reboot the target and confirm the foothold returns.
- Document how you would disguise it and what log evidence it leaves.
- Detect persistence by inspecting the registry; map each finding to its ATT&CK technique.

Graded on observable outcomes — a foothold that survives reboot and a correct detection write-up. Hack The Box accepted where equivalent material exists.

Key Takeaways

- Persistence keeps the foothold across reboots — it is the attacker's safety net.
- MITRE ATT&CK TA0003 catalogs the techniques; attackers layer more than one.
- Footholds blend in with common service names, legitimate-looking tasks, and living off the land.
- Detect it by its anomalies — odd hours, long-lived connections, stray autostart entries.

MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Questions?

Unit 10 · Persistence

MID-STATE TECHNICAL COLLEGE